

Отчет по второму этапу индивидуального проекта

Основы информационной безопасности

Шихалиева Зурият, НПибд-03-23

Содержание

1	Цель работы	5
2	Задание	6
3	Теоретическое введение	7
4	Выполнение лабораторной работы	9
5	Выводы	17
	Список литературы	18

Список иллюстраций

4.1	Клонирование репозитория	9
4.2	Изменение прав доступа	9
4.3	Перемещение по директориям	10
4.4	Создание копии файла	10
4.5	Открытие файла в редакторе	10
4.6	Редактирование файл	11
4.7	Запуск mysql	11
4.8	Авторизация в базе данных	12
4.9	Изменение прав	12
4.10	Перемещение между директориями	12
4.11	Открытие файла в текстовом редакторе	13
4.12	Редактирование файла	13
4.13	Запуск arche	14
4.14	Запуск веб-приложения	14
4.15	“Создание базы данных”	15
4.16	Авторизация	15
4.17	Домашняя страница DVWA	16

Список таблиц

1 Цель работы

Приобретение практических навыков по установке DVWA.

2 Задание

1. Установить DVWA на дистрибутив Kali Linux.

3 Теоретическое введение

DVWA - это уязвимое веб-приложение, разработанное на PHP и MySQL.

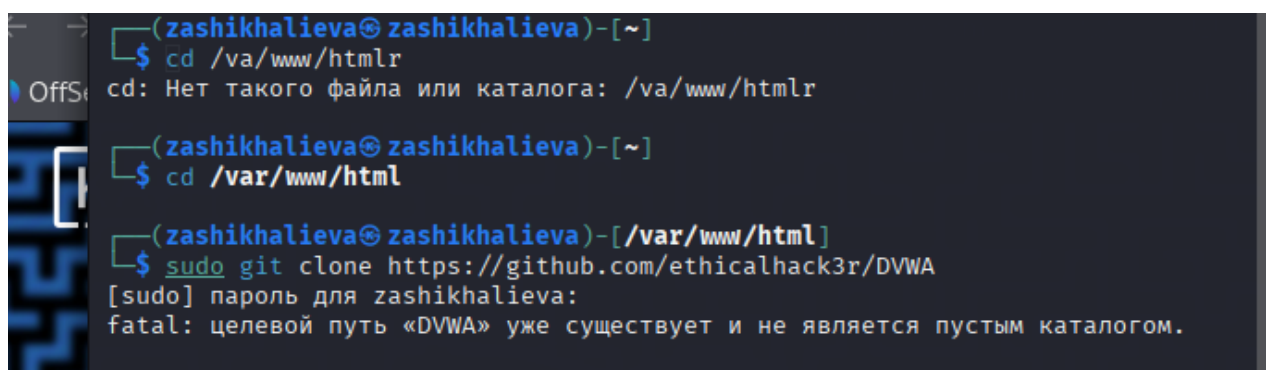
Некоторые из уязвимостей веб приложений, который содержит DVWA: - Брутфорс: Брутфорс HTTP формы страницы входа - используется для тестирования инструментов по атаке на пароль методом грубой силы и показывает небезопасность слабых паролей. - Исполнение (внедрение) команд: Выполнение команд уровня операционной системы. - Межсайтовая подделка запроса (CSRF): Позволяет «атакующему» изменить пароль администратора приложений. - Внедрение (инклюд) файлов: Позволяет «атакующему» присоединить удалённые/локальные файлы в веб приложение. - SQL внедрение: Позволяет «атакующему» внедрить SQL выражения в HTTP из поля ввода, DVWA включает слепое и основанное на ошибке SQL внедрение. - Небезопасная выгрузка файлов: Позволяет «атакующему» выгрузить вредоносные файлы на веб сервер. - Межсайтовый скриптинг (XSS): «Атакующий» может внедрить свои скрипты в веб приложение/базу данных. DVWA включает отражённую и хранимую XSS. - Пасхальные яйца: раскрытие полных путей, обход аутентификации и некоторые другие.

DVWA имеет четыре уровня безопасности, они меняют уровень безопасности каждого веб приложения в DVWA: - Невозможный — этот уровень должен быть безопасным от всех уязвимостей. Он используется для сравнения уязвимого исходного кода с безопасным исходным кодом. - Высокий — это расширение среднего уровня сложности, со смесью более сложных или альтернативных плохих практик в попытке обезопасить код. Уязвимости не позволяют такой простор

эксплуатации как на других уровнях. - Средний — этот уровень безопасности предназначен главным образом для того, чтобы дать пользователю пример плохих практик безопасности, где разработчик попытался сделать приложение безопасным, но потерпел неудачу. - Низкий — этот уровень безопасности совершенно уязвим и совсем не имеет защиты. Его предназначение быть примером среди уязвимых веб приложений, примером плохих практик программирования и служить платформой обучения базовым техникам эксплуатации. [2]

4 Выполнение лабораторной работы

Настройка DVWA происходит на нашем локальном хосте, поэтому нужно перейти в директорию `/var/www/html`. Затем клонирую нужный репозиторий GitHub (рис. 1).



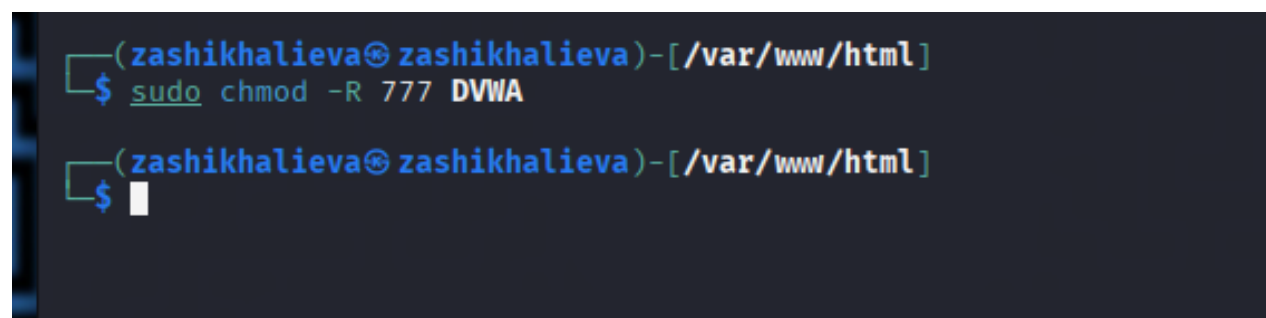
```
(zashikhalieva@zashikhalieva)-[~]
$ cd /va/www/htmlr
cd: Нет такого файла или каталога: /va/www/htmlr

(zashikhalieva@zashikhalieva)-[~]
$ cd /var/www/html

(zashikhalieva@zashikhalieva)-[/var/www/html]
$ sudo git clone https://github.com/ethicalhack3r/DVWA
[sudo] пароль для zashikhalieva:
fatal: целевой путь «DVWA» уже существует и не является пустым каталогом.
```

Рис. 4.1: Клонирование репозитория

Проверяю, что файлы скопировались правильно, далее повышаю права доступа к этой папке до 777 (рис. 2.)



```
(zashikhalieva@zashikhalieva)-[/var/www/html]
$ sudo chmod -R 777 DVWA

(zashikhalieva@zashikhalieva)-[/var/www/html]
$
```

Рис. 4.2: Изменение прав доступа

Чтобы настроить DVWA, нужно перейти в каталог `/dvwa/config`, затем проверить содержимое каталога (рис. 3)

```
(zashikhalieva@zashikhalieva)-[/var/www/html]
$ cd DVWA/config

(zashikhalieva@zashikhalieva)-[/var/www/html/DVWA/config]
$ ls
config.inc.php      config.inc.php.dist
config.inc.php.bak  config.inc.php.save
```

Рис. 4.3: Перемещение по директориям

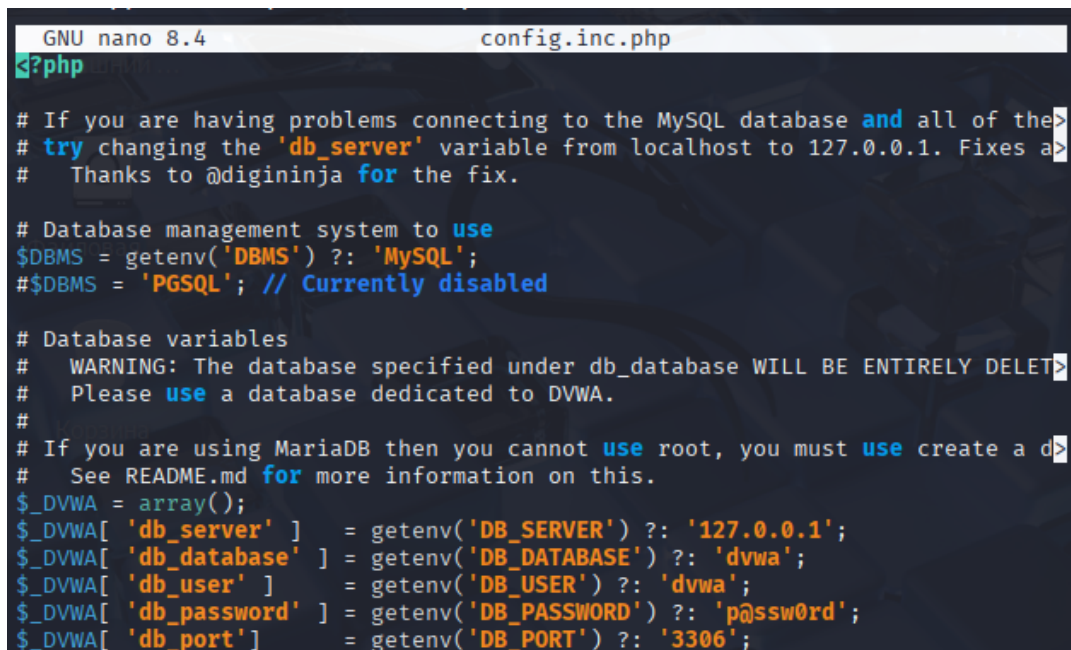
Создаем копию файла, используемого для настройки DVWA `config.inc.php.dist` с именем `config.inc.php`. Копируем файл, а не изменяем его, чтобы у нас был запасной вариант, если что-то пойдет не так (рис. 4)

```
(zashikhalieva@zashikhalieva)-[/var/www/html/DVWA/config]
$ sudo cp config.inc.php.dist config.inc.php

(zashikhalieva@zashikhalieva)-[/var/www/html/DVWA/config]
$ ls
config.inc.php      config.inc.php.dist
config.inc.php.bak  config.inc.php.save
```

Рис. 4.4: Создание копии файла

Далее открываю файл в текстовом редакторе (рис. 5)

A screenshot of a terminal window showing the GNU nano 8.4 text editor editing the file config.inc.php. The editor has a dark background with syntax-highlighted PHP code. The code includes comments about database connection issues, database management system settings (MySQL vs PostgreSQL), database variables, and DVWA configuration parameters like db_server, db_database, db_user, db_password, and db_port.

```
GNU nano 8.4 config.inc.php
?php

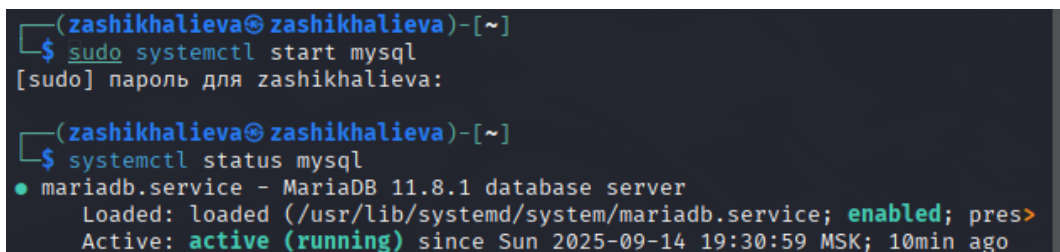
# If you are having problems connecting to the MySQL database and all of the
# try changing the 'db_server' variable from localhost to 127.0.0.1. Fixes a
# Thanks to @digininja for the fix.

# Database management system to use
$DBMS = getenv('DBMS') ?: 'MySQL';
#$DBMS = 'PGSQL'; // Currently disabled

# Database variables
# WARNING: The database specified under db_database WILL BE ENTIRELY DELETED
# Please use a database dedicated to DVWA.
#
# If you are using MariaDB then you cannot use root, you must create a database
# See README.md for more information on this.
$_DVWA = array();
$_DVWA['db_server'] = getenv('DB_SERVER') ?: '127.0.0.1';
$_DVWA['db_database'] = getenv('DB_DATABASE') ?: 'dvwa';
$_DVWA['db_user'] = getenv('DB_USER') ?: 'dvwa';
$_DVWA['db_password'] = getenv('DB_PASSWORD') ?: 'p@ssw0rd';
$_DVWA['db_port'] = getenv('DB_PORT') ?: '3306';
```

Рис. 4.6: Редактирование файла

По умолчанию в Kali Linux установлен mysql, поэтому можно его запустить без предварительного скачивания, далее выполняю проверку, запущен ли процесс (рис. 7)

A screenshot of a terminal window showing a user named zashikhalieva at a prompt. The user runs 'sudo systemctl start mysql' and enters a password. Then, they run 'systemctl status mysql' to check the service status. The output shows that mariadb.service is loaded and active (running).

```
(zashikhalieva@zashikhalieva)-[~]
$ sudo systemctl start mysql
[sudo] пароль для zashikhalieva:

(zashikhalieva@zashikhalieva)-[~]
$ systemctl status mysql
● mariadb.service - MariaDB 11.8.1 database server
   Loaded: loaded (/usr/lib/systemd/system/mariadb.service; enabled; pres>
   Active: active (running) since Sun 2025-09-14 19:30:59 MSK; 10min ago
```

Рис. 4.7: Запуск mysql

Авторизируюсь в базе данных от имени пользователя root. Появляется командная строка с приглашением “MariaDB”, далее создаем в ней нового пользователя, используя учетные данные из файла config.inc.php (рис. 8)

```

(zashikhalieva@zashikhalieva)-[~]
$ sudo mysql -u root -p
[sudo] пароль для zashikhalieva:
Enter password:
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MariaDB connection id is 31
Server version: 11.8.1-MariaDB-4 Debian n/a

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Support MariaDB developers by giving a star at https://github.com/MariaDB/se
rver
Type 'help;' or '\h' for help. Type '\c' to clear the current input statemen

```

Рис. 4.8: Авторизация в базе данных

Теперь нужно пользователю предоставить привилегии для работы с этой базой данных (рис. 9)

```

MariaDB [(none)]> exit
Bye

```

Рис. 4.9: Изменение прав

Необходимо настроить сервер apache2, перехожу в соответствующую директорию (рис. 10)

```

(zashikhalieva@zashikhalieva)-[~]
$ cd /etc/php/8.4/apache2

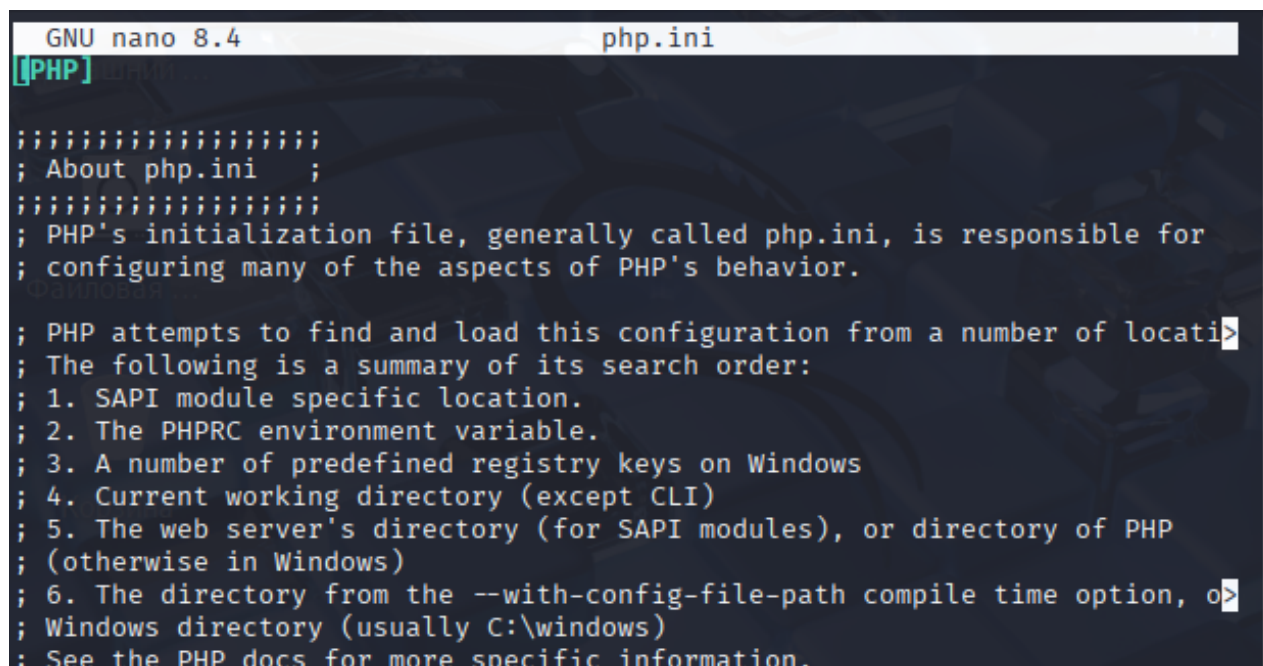
(zashikhalieva@zashikhalieva)-[/etc/php/8.4/apache2]
$ █

```

Рис. 4.10: Перемещение между директориями

В файле `php.ini` нужно будет изменить один параметр, поэтому открываю файл в текстовом редакторе (рис. 11)

```
(zashikhalieva@zashikhalieva)-[/etc/php/8.4/apache2]  
$ sudo nano php.ini
```



```
GNU nano 8.4 php.ini  
[PHP]  
  
;;;;;;;;;;;;;;;;;  
; About php.ini  ;  
;;;;;;;;;;;;;;;;;  
; PHP's initialization file, generally called php.ini, is responsible for  
; configuring many of the aspects of PHP's behavior.  
  
; PHP attempts to find and load this configuration from a number of locati>  
; The following is a summary of its search order:  
; 1. SAPI module specific location.  
; 2. The PHPRC environment variable.  
; 3. A number of predefined registry keys on Windows  
; 4. Current working directory (except CLI)  
; 5. The web server's directory (for SAPI modules), or directory of PHP  
; (otherwise in Windows)  
; 6. The directory from the --with-config-file-path compile time option, o>  
; Windows directory (usually C:\windows)  
; See the PHP docs for more specific information.
```

Рис. 4.12: Редактирование файла

Запускаем службу веб-сервера apache и проверяем, запущена ли служба (рис. 13)

```
(zashikhalieva@zashikhalieva)-[/etc/php/8.4/apache2]
$ systemctl status start apache2
Unit start.service could not be found.
● apache2.service - The Apache HTTP Server
   Loaded: loaded (/usr/lib/systemd/system/apache2.service; enabled; pre>
   Active: active (running) since Sun 2025-09-14 19:30:58 MSK; 23min ago
  Invocation: 0a8559eaf4eb4c5baf8c0e00c7706b2d
     Docs: https://httpd.apache.org/docs/2.4/
  Process: 714 ExecStart=/usr/sbin/apachectl start (code=exited, status=>
 Main PID: 837 (apache2)
    Tasks: 6 (limit: 7720)
  Memory: 23.7M (peak: 24M)
     CPU: 176ms
   CGroup: /system.slice/apache2.service
           └─837 /usr/sbin/apache2 -k start
             └─846 /usr/sbin/apache2 -k start
               └─847 /usr/sbin/apache2 -k start
                 └─848 /usr/sbin/apache2 -k start
                   └─849 /usr/sbin/apache2 -k start
                     └─850 /usr/sbin/apache2 -k start

сен 14 19:30:57 zashikhalieva systemd[1]: Starting apache2.service - The A>
сен 14 19:30:57 zashikhalieva apachectl[767]: AH00557: apache2: apr sockad>
```

Рис. 4.13: Запуск apache

Мы настроили DVWA, Apache и базу данных, поэтому открываем браузер и запускаем веб-приложение, введя 127.0.0/DVWA (рис. 14)

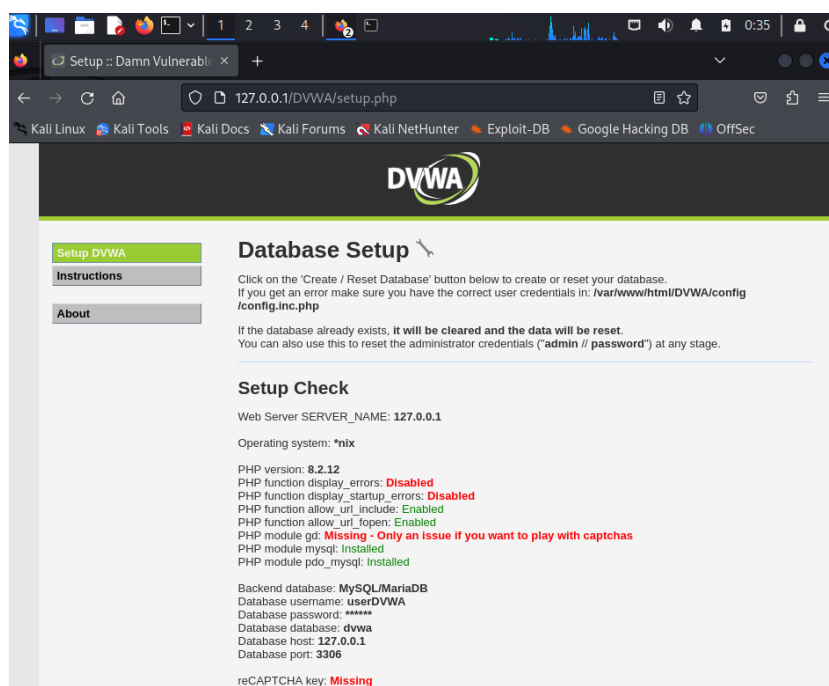


Рис. 4.14: Запуск веб-приложения

Прокручиваем страницу вниз и нажимаем на кнопку create\reset database

(рис. 15)

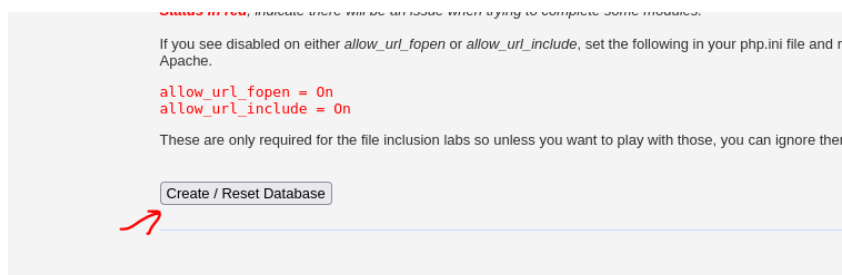


Рис. 4.15: “Создание базы данных”

Авторизуюсь с помощью предложенных по умолчанию данных (рис. 16)

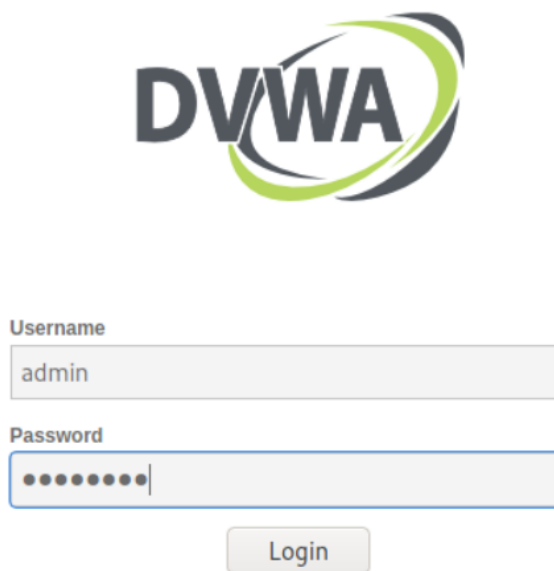


Рис. 4.16: Авторизация

Оказываюсь на домашней странице веб-приложения, на этом установка окончена (рис. 17)

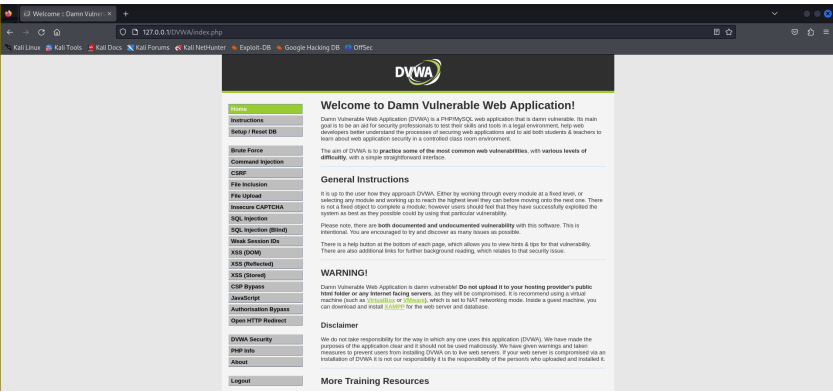


Рис. 4.17: Домашняя страница DVWA

5 Выводы

Приобрела практические навыки по установке уязвимого веб-приложения DVWA.

Список литературы

1. How to install DVWA on Kali-Linux for pentesting practice [Электронный ресурс]. 2021. URL: <http://nooblinux.com/how-to-install-dvwa/>.
2. Ш. Парасрам Т.Х.и.др. А. Замм. Kali Linux: Тестирование на проникновение и безопасность: для профессионалов. Питер, 2022. 448 с.